

Know Your Agent Working Group
Request for Comments: AP-1
Category: Standards Track (proposed)

T. Cvikl
A. Tran
B. Liu
J. Burnazyan
Legis Labs Ltd
6 September 2026

Agent Passport: A Standard for Agent-Initiated Payments

Status of this Memo

This memo proposes a standard by which a payment institution's autonomous software agent proves, before a payment executes, that it acts within a current, human-granted authority. It is a proposal for discussion, demonstrated on synthetic data. It does not describe a current legal requirement. Distribution is unlimited.

Abstract

An agent that can be identified can still act beyond what its principal allowed. This document separates identity from authority. An Agent Passport is an envelope of three signed claims, each made by the only party entitled to make it: the supervisory authority, the provider operating the agent, and the customer whose funds are at stake. A relying bank verifies the envelope and the signed instruction with an ordered, deny-by-default procedure and answers ALLOW, ESCALATE or DENY with a rule citation and a signed receipt. Authority may be delegated but never expanded. Revocation is a registry lookup. Every decision is replayable.

1. Introduction

Firms delegate invoice payment to AI agents. A bank receiving an instruction cannot determine which agent sent it, whether it was permitted to, or who answers for it. Since 2024, UK banks bear the loss when a misdirected payment is authorised. This standard gives the bank one verification call that answers those three questions before money moves.

The key words MUST, MUST NOT and SHOULD are to be interpreted as described in RFC 2119.

2. Terminology

Authority	The supervisor that assures the provider and its agent and maintains the status registry.
Provider	The regulated institution operating the agent.
Customer	The legal person whose funds the agent moves.

Agent Software holding a private key, acting for the
 provider on the customer's behalf.
Relying party The bank that executes payment instructions.
Passport The envelope defined in Section 3.

3. The Passport

A passport MUST consist of three signed tokens (JWT, RFC 7519; EdDSA, RFC 8037) and an identifier:

assurance	signed by the AUTHORITY: provider licence, assurance status, supervisor condition, validity, registry pointer, and the hash of the agent_identity it was issued for.
agent_identity	signed by the PROVIDER: agent name, agent public key (cnf, RFC 7800), software and configuration hash.
mandate	signed by the CUSTOMER: permitted actions, payee allow-list by account, per-payment ceiling, rolling monthly ceiling, expiry, as an authorization_details object (RFC 9396).

No party MAY alter a claim it did not sign. A passport carries permission, not personal data.

4. Verification Procedure

The agent MUST sign every instruction with the key named in agent_identity. The relying party MUST evaluate the following in order and stop at the first failure:

R.1	assurance signature verifies (authority key)
R.2	assurance ACTIVE and unexpired (registry lookup)
R.3	agent_identity verifies and is bound to this assurance
R.4	instruction signed by the agent key in agent_identity
R.5	mandate present, customer-signed, unexpired
R.6	action permitted; payee account on the allow-list
R.7	amount within the per-payment ceiling
R.8	amount plus the relying party's own rolling total within the monthly ceiling
R.9	amount above the supervisor condition -> ESCALATE
else	-> ALLOW

The result MUST cite the rule that decided it and MUST be accompanied by a receipt signed by the authority. Ceilings live in the mandate; running totals live at the relying party.

5. Delegation

Where an agent delegates to another, the delegation MUST be signed by the delegating key, and for scopes S0 (mandate), S1 ... Sn:

S_n is a subset of ... S_1 is a subset of S_0 , and the action is an element of S_n .

Delegation MAY narrow authority. It MUST NOT expand it.

6. Lifecycle

Issue	Evidence is read into cited facts; written rules are applied; adversarial cases are run through the procedure of Section 4; a human officer decides and the authority signs. No machine MAY issue.
Act	The relying party verifies each instruction.
Detect	Every refusal is recorded. A repeated refusal of the same rule SHOULD raise an alert to the authority.
Revoke	The authority sets the registry status. The next instruction fails at R.2 on every rail that mirrors the mandate.
Replay	Every decision MUST be reproducible from its recorded inputs.

7. Security Considerations

A copied passport is useless without the agent's private key (R.4). A forged or altered claim fails its signature (R.1, R.3, R.5). A manipulated agent that requests payment to an account the customer never listed fails R.6 regardless of how genuine the invoice appeared. Compromise of the authority's key, and attestation of the running software, are out of scope.

8. What This Standard Does Not Specify

Settlement. Know-your-customer, sanctions or funds checks. Whether a payment is wise. Any judgement by a model: models read and draft; rules decide; humans sign.

9. References

RFC 2119, RFC 7519 (JWT), RFC 7800 (cnf), RFC 8037 (EdDSA), RFC 9396 (Rich Authorization Requests), W3C Verifiable Credentials (JWT profile), NIST NCCoE 2026 (agent identity and authorization), FATF 2025 (AI and AML/CFT).

Authors' Addresses

Legis Labs Ltd, Cambridge, United Kingdom.
Reference implementation: <https://pay.cdir.legislabs.uk>
Source: <https://github.com/LegisLabs/agent-passport>